

GlobalTrust Financial Services

Information Security Policy

Document ID	GTFS-SEC-001
Version	3.2
Classification	Internal
Owner	Information Security Department
Approved By	Priya Raman, Chief Information Security Officer (CISO)
Effective Date	01 January 2026
Review Date	01 January 2027

Table of Contents

1. Purpose
2. Scope
3. Security Principles
4. Roles & Responsibilities
5. Data Classification
6. Access Control
7. Authentication
8. Device Security
9. Network Security
10. Email Security
11. Cloud Security
12. Remote Work Security
13. Incident Response
14. Security Monitoring
15. Regulatory Compliance
16. Security Awareness
17. Policy Violations
18. Frequently Asked Questions
19. Appendices

1. Purpose

Information security is foundational to GlobalTrust Financial Services (GTFS). As a multinational financial institution serving 4,850 employees and millions of customers from our Singapore headquarters and regional offices, we are entrusted with sensitive financial data, payment systems, and regulatory obligations that demand the highest standards of protection.

Customer Trust — Security breaches erode confidence. GTFS protects customer assets and personal data to maintain the trust that underpins our business.

Regulatory Compliance — MAS, PCI DSS, GDPR, and local banking regulations require demonstrable security controls. Non-compliance carries significant penalties.

Cybersecurity Threats — Ransomware, phishing, and advanced persistent threats target financial institutions daily. Proactive defence is essential.

Business Continuity — Security incidents disrupt operations. This policy aligns with the Disaster Recovery Plan (GTFS-BCP-001) and Risk Management Framework (GTFS-RISK-001).

Data Protection — Classification, encryption, and retention controls safeguard information throughout its lifecycle per the Data Retention Policy (GTFS-LEGAL-001).

POLICY NOTE: This policy is the master security document for GTFS. Detailed requirements for passwords and MFA are in GTFS-SEC-002; VPN procedures are in GTFS-SEC-003.

Policy Hierarchy

Document	ID	Scope
Employee Handbook	GTFS-HR-001	General employee obligations
Remote Work Policy	GTFS-HR-002	Hybrid and remote security
Information Security Policy	GTFS-SEC-001	Master security policy (this document)
Password & MFA Policy	GTFS-SEC-002	Authentication standards
VPN Access Guide	GTFS-SEC-003	Remote connectivity
Risk Management Framework	GTFS-RISK-001	Enterprise risk governance
Data Retention Policy	GTFS-LEGAL-001	Data lifecycle management
Disaster Recovery Plan	GTFS-BCP-001	Business continuity and recovery

2. Scope

This policy applies to all individuals and entities with access to GTFS information systems or data:

- **Employees** — all full-time, part-time, and probationary staff.
- **Contractors** — engaged for defined projects or operational support.
- **Third-party vendors** — suppliers with system or data access.
- **Interns** — temporary programme participants.
- **Consultants** — external advisors with GTFS credentials.
- **Cloud providers** — under contractual security obligations.
- **Partners** — joint venture and alliance entities as defined in agreements.

All parties must acknowledge this policy before receiving access. The Employee Handbook (GTFS-HR-001) references employee security obligations.

Geographic Coverage

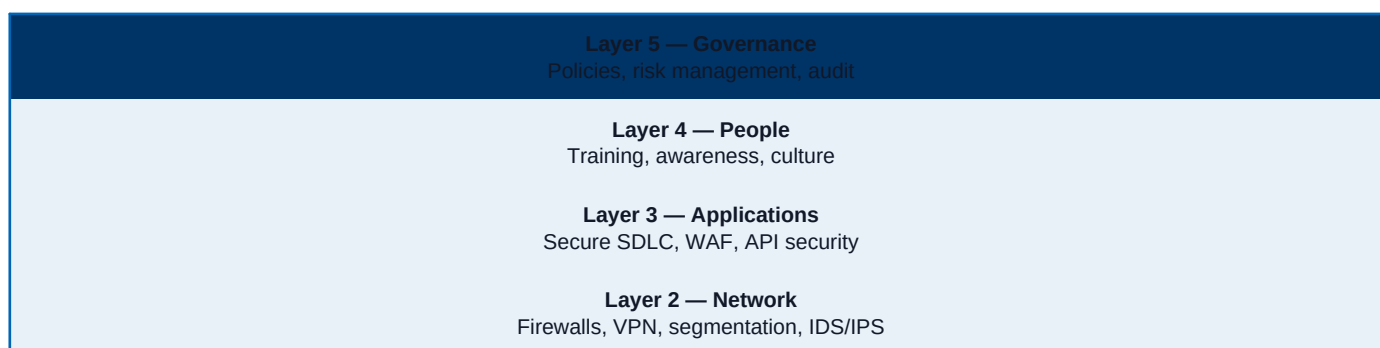
This policy applies across all GTFS operations in Singapore (headquarters), Dubai, Mumbai, and London. Regional security officers ensure local regulatory requirements are incorporated without weakening baseline controls.

POLICY NOTE: Third-party vendors processing GTFS data must undergo security assessments and sign data processing agreements before access is granted.

3. Security Principles

- **Confidentiality** — Information accessible only to authorised individuals.
- **Integrity** — Data accurate, complete, and protected from unauthorised modification.
- **Availability** — Systems and data accessible when required for business operations.
- **Least Privilege** — Minimum access necessary to perform job functions.
- **Need to Know** — Access granted based on business requirement, not convenience.
- **Zero Trust** — Never trust, always verify; authenticate and authorise every access request.
- **Defense in Depth** — Multiple layers of controls; no single point of failure.

Defense-in-Depth Architecture



Layer 1 — Endpoint

EDR, encryption, patching, MFA

Layer 0 — Data

Classification, encryption, DLP, retention

4. Roles & Responsibilities

Role	Security Responsibilities
Board of Directors	Oversee cyber risk; approve security strategy and major investments
CEO	Ultimate accountability; champion security culture across the organisation
CISO (Priya Raman)	Define policy; manage SOC; report to Board Risk Committee quarterly
IT Department	Implement controls; patch management; infrastructure security
Security Operations Center	24x7 monitoring; incident detection and initial response
Managers	Ensure team compliance; approve access; enforce policy violations
Employees	Follow policy; report incidents; complete mandatory training
Vendors	Comply with contractual security requirements; undergo assessments

5. Data Classification

All GTFS data must be classified at creation. Classification determines handling, encryption, sharing, retention, and disposal requirements.

Level	Examples	Handling	Encryption	Sharing	Retention	Disposal
Public	Marketing, press releases	No restrictions	Optional	Unrestricted	Per policy	Standard delete
Internal	Org charts, policies	GTFS staff only	In transit	Internal email	7 years	Secure delete
Confidential	Customer PII, financials	Need-to-know	At rest + transit	Approved channels	Per GTFS-LEGAL-001	Controlled wipe
Restricted	Credentials, keys, POs	Named individuals	Mandatory AES-256	Prohibited external	Regulatory minimum	Crypto-shred + audit

Classification Handling Procedures

- **Public** — May be published externally without approval.
- **Internal** — Share via GTFS email or internal portals only.
- **Confidential** — Encrypt before transmission; watermark PDFs where possible.
- **Restricted** — Access logged; printing prohibited; secure disposal mandatory.

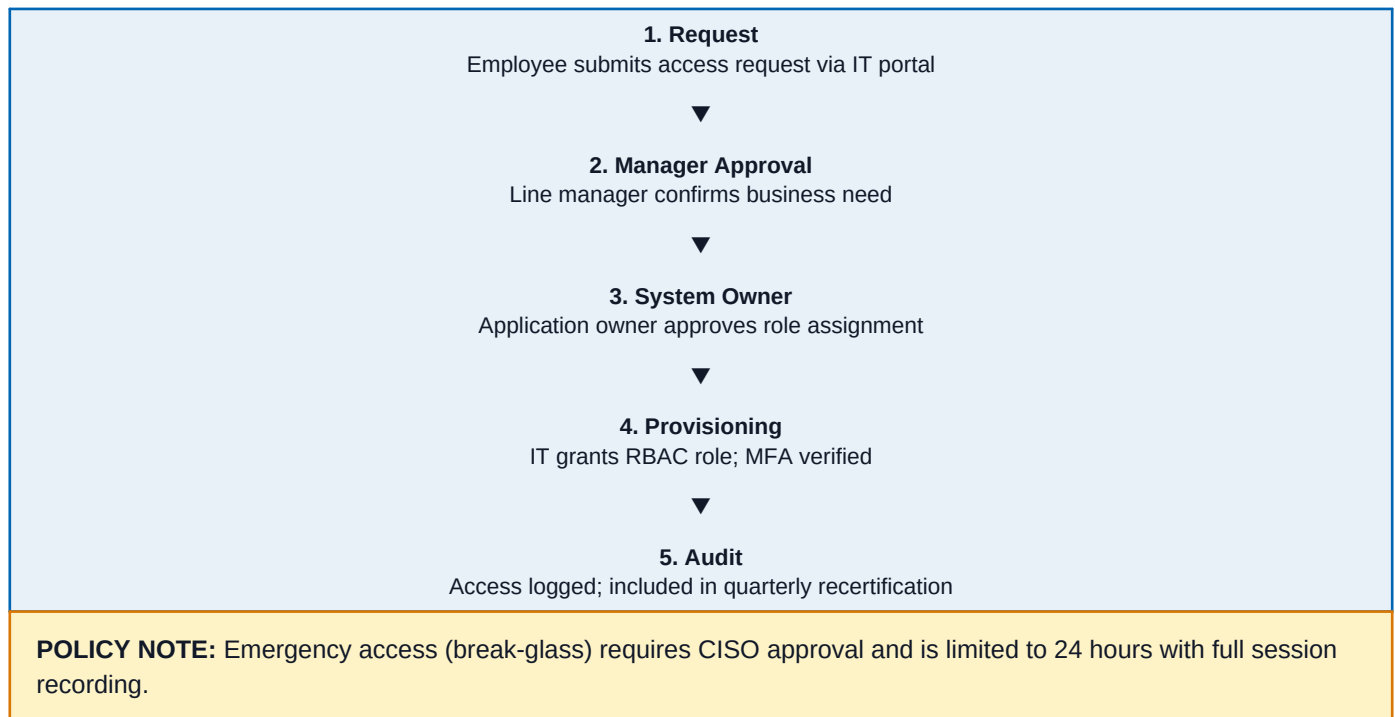
WARNING: Misclassification of Restricted data is a serious violation. When in doubt, classify at the higher level and consult the Information Security team.

6. Access Control

GTFS implements Role-Based Access Control (RBAC) aligned with job functions. Access is granted on the principle of least privilege and need-to-know basis.

Control	Requirement
RBAC	Permissions mapped to roles in identity management system
Least Privilege	Default deny; explicit grant only
Privileged Access Management (PAM)	Admin accounts vaulted; session recording enabled
Periodic Access Reviews	Quarterly recertification by managers and system owners
Account Provisioning	HR-triggered workflow; manager approval required
Account Deprovisioning	Access revoked within 24 hours of termination or role change

Access Request Workflow



7. Authentication

Strong authentication protects GTFS systems from unauthorised access. Detailed password and MFA requirements are specified in the Password & MFA Policy (GTFS-SEC-002).

Password Standards

All GTFS passwords must meet complexity requirements defined in GTFS-SEC-002. Passwords are subject to maximum age limits and history restrictions to prevent reuse of compromised credentials. Accounts lock after repeated failed authentication attempts and require manager or helpdesk intervention for early unlock.

Multi-Factor Authentication

MFA is mandatory for all users accessing GTFS systems, including email, VPN, and internal applications. Biometric authentication is permitted on approved mobile devices when registered through the corporate MDM platform, with hardware token or app-based MFA as fallback.

Session Management

Single Sign-On (SSO) is required for all GTFS applications where technically supported. Interactive sessions expire after **20 minutes** of inactivity. Users must not disable session timeout controls or use browser extensions that bypass authentication.

Control	Standard
Biometric authentication	Approved mobile devices only; MFA fallback required
Single Sign-On (SSO)	Mandatory where supported
Service accounts	Certificate-based auth; no interactive passwords
Shared accounts	Prohibited except break-glass with CISO approval

SECURITY BEST PRACTICES: Never share credentials or approve MFA prompts you did not initiate. Report suspicious authentication activity to the SOC immediately.

8. Device Security

Corporate Laptops

All GTFS laptops enforce **AES-256 BitLocker** full-disk encryption. Screen lock activates automatically after five minutes. Users must not disable encryption or EDR agents.

Patching & USB Controls

Critical security patches are deployed within **48 hours** of release. **USB storage is disabled by default** on all endpoints. Exceptions for encrypted corporate USB drives require written CISO approval and are logged.

Control	Requirement
Corporate laptops	GTFS-managed; no personal devices for business data
Mobile devices	MDM-enrolled; encryption mandatory
Antivirus / EDR	GTFS endpoint agent; tamper protection enabled

Control	Requirement
Automatic patching	Managed by IT; user deferral prohibited for critical updates
Screen lock	Automatic after 5 minutes; password/PIN required

Mobile device encryption is **mandatory** for any device accessing GTFS email or applications. Lost devices must be reported within 30 minutes for remote wipe.

Patch Management SLAs

Severity	Definition	Remediation SLA	Example
Critical	CVSS 9.0–10.0; actively exploited	48 hours	Remote code execution
High	CVSS 7.0–8.9; significant impact	7 days	Privilege escalation
Medium	CVSS 4.0–6.9; moderate impact	30 days	Information disclosure
Low	CVSS 0.1–3.9; minimal impact	90 days	Minor configuration issue

9. Network Security

- **VPN** — Mandatory for remote access; idle timeout after 15 minutes (see GTFS-SEC-003).
- **Firewalls** — Perimeter and internal firewalls enforce deny-by-default rules.
- **IDS/IPS** — Intrusion detection and prevention on critical network segments.
- **Network segmentation** — Production, development, and DMZ environments isolated.
- **DNS filtering** — Blocks known malicious domains and command-and-control servers.
- **Secure Wi-Fi** — WPA3-Enterprise for corporate networks.
- **Guest Wi-Fi** — Internet access only; no access to GTFS internal resources.

SECURITY TIP: Never bridge guest and corporate networks. Do not connect personal hotspots to GTFS devices.

Network Architecture Overview

Zone	Purpose	Access Controls
Internet DMZ	Public-facing web services	WAF, DDoS protection, TLS 1.3
Application Tier	Business applications	Internal firewall, RBAC
Data Tier	Databases, storage	Strict segmentation; no direct internet
Management Network	Administration, monitoring	Jump hosts, PAM, MFA
Development	Non-production environments	Isolated; no production data

10. Email Security

Email remains a primary attack vector. GTFS deploys advanced filtering for phishing, Business Email Compromise (BEC), spam, and malware.

Threat	Control	Employee Action
Phishing	AI-based detection; warning banners	Report within 15 minutes via 'Report Phishing' button
BEC	DMARC/DKIM/SPF; sender verification	Verify payment requests via phone
Spam	Gateway filtering	Do not unsubscribe from suspicious emails
Malware	Sandbox attachment analysis	Do not open unexpected attachments
Safe links	URL rewriting and scanning	Hover before clicking; report suspicious links

Email attachment size limit is **25 MB**. Larger files must use approved secure file transfer.

11. Cloud Security

GTFS operates in approved cloud environments only. Unapproved cloud services are prohibited.

Platform	Purpose	Security Controls
Microsoft 365	Email, collaboration, identity	DLP, MFA, conditional access
Microsoft Azure	Application hosting, data analytics	Encryption, RBAC, logging
AWS	Disaster recovery, sandbox environments	IAM, CloudTrail, GuardDuty

Approved infrastructure cloud platforms are **Microsoft Azure** and **AWS**. All cloud workloads require security architecture review. Identity management integrates with corporate SSO. Encryption at rest and in transit is mandatory. Cloud logs are ingested into the SIEM with **365-day retention**.

12. Remote Work Security

Remote and hybrid employees must comply with the Remote Work Policy (GTFS-HR-002) and the following security requirements:

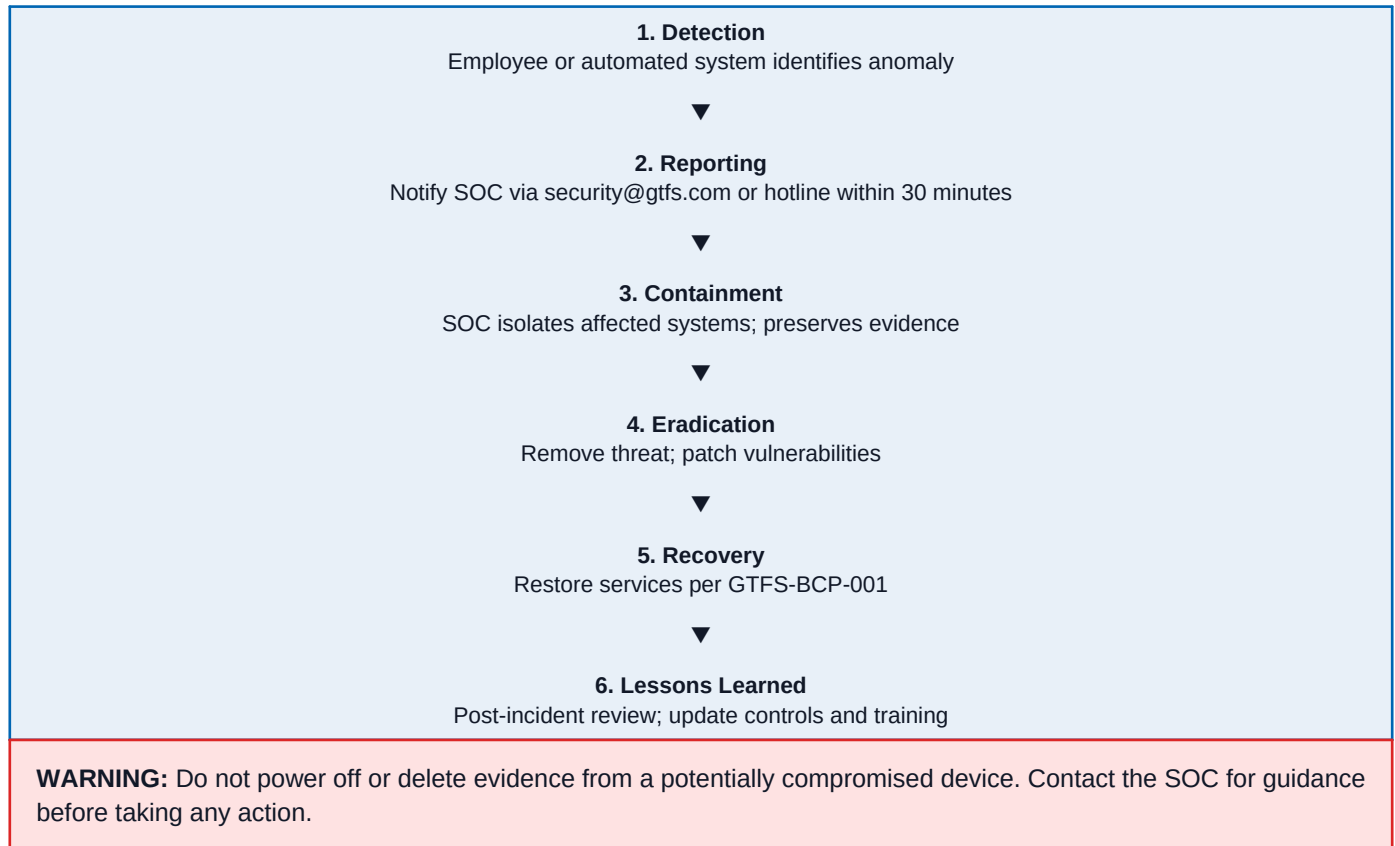
- Connect via corporate VPN for all GTFS system access.
- Use secure home Wi-Fi (WPA2/WPA3); never use public Wi-Fi without active VPN.
- Do not print confidential documents at home without CISO approval.
- Conduct confidential conversations in private spaces away from others.
- Enable camera and microphone controls in video meetings; use GTFS virtual backgrounds.
- Store work data only on encrypted GTFS devices; no local copies on personal storage.

Remote Work Control	Requirement	Reference
VPN connection	Mandatory; 15-minute idle timeout	GTFS-SEC-003
Home Wi-Fi	WPA2/WPA3; unique network password	GTFS-HR-002 Section 7
Printing	Prohibited for Confidential/Restricted	CISO exception only

Remote Work Control	Requirement	Reference
Video meetings	GTFS Teams only; no personal Zoom/Skype	GTFS-HR-002 Section 10

13. Incident Response

Security incidents must be reported to the SOC within **30 minutes** of discovery. Employees are the first line of detection.



Incident Severity Classification

Severity	Criteria	Response Time	Escalation
P1 — Critical	Active breach; customer data at risk	15 minutes	CISO + CEO notification
P2 — High	Confirmed malware; system compromise	30 minutes	CISO notification
P3 — Medium	Suspected incident; contained threat	2 hours	SOC manager
P4 — Low	Policy violation; no active threat	24 hours	Team lead

14. Security Monitoring

Capability	Description	Frequency / SLA
SIEM	Centralised log aggregation and correlation	Log review 24×7 by SOC
SOC	Security Operations Centre — Singapore	24×7 monitoring and response
Threat Intelligence	Commercial and ISAC feeds	Continuous ingestion
Log monitoring	All critical systems	365-day retention
User Activity Monitoring	Privileged and anomalous behaviour	Real-time alerting
Vulnerability Management	Scanning and remediation tracking	Weekly vulnerability scans
Penetration Testing	External and internal assessments	Twice annually

Vulnerability remediation SLAs: **critical patches within 48 hours, high-risk within 7 days, medium-risk within 30 days.**

15. Regulatory Compliance

Framework / Regulation	Applicability	GTFS Control Alignment
ISO 27001	Information security management	Certified; annual surveillance audit
PCI DSS	Payment card processing	Level 1 merchant; quarterly scans
GDPR	EU personal data	Privacy by design; DPO oversight
MAS TRM	Singapore technology risk	Risk Management Framework GTFS-RISK-001
Local Banking Regulations	RBI, DFSA, FCA	Regional compliance officers
Internal Audit	Independent assurance	Annual security audit programme

Compliance Monitoring Activities

- Quarterly PCI DSS vulnerability scans for cardholder data environments.
- Annual ISO 27001 surveillance audit by accredited certification body.
- MAS TRM self-assessment submitted to Board Risk Committee semi-annually.
- GDPR data protection impact assessments for new processing activities.
- Internal audit security reviews covering access, change management, and incidents.

16. Security Awareness

All employees must complete **8 hours** of mandatory security training annually, including an annual refresher module. Training completion is tracked in the learning management system and linked to performance reviews.

- **Quarterly phishing simulations** — required participation; failures trigger remedial training.
- Security awareness campaigns — monthly newsletters, posters, and town hall briefings.
- Role-specific training for developers, administrators, and privileged users.
- New hire security induction within first five business days.

Password hygiene is reinforced during training: employees must use passwords of at least **14 characters**, change them every **90 days**, and must not reuse any of their **last 12 passwords**. Accounts lock after **5 failed login attempts**.

Training Module	Audience	Duration	Frequency
Security Fundamentals	All employees	4 hours	Annual
Phishing Awareness	All employees	1 hour	Quarterly refresher
Data Classification	All employees	1 hour	Annual
Secure Coding	Developers	8 hours	Annual
Privileged Access	Administrators	4 hours	Annual

WARNING: Employees who fail quarterly phishing simulations must complete remedial training within five business days. Repeated failures may result in access suspension.

17. Policy Violations

Examples of violations include:

- Sharing credentials or bypassing MFA.
- Installing unauthorised software or disabling security agents.
- Storing Restricted data on personal devices or unapproved cloud services.
- Failure to report security incidents or phishing within required timeframes.
- Circumventing USB restrictions or network segmentation.

Severity	Examples	Consequences
Low	Minor policy deviation; first occurrence	Verbal warning; remedial training
Medium	Repeated violations; negligent handling	Written warning; access suspension
High	Intentional bypass; data exfiltration attempt	Termination; regulatory reporting
Critical	Fraud; criminal activity	Termination; law enforcement referral

Escalation path: Line Manager → CISO → HR → Legal. Disciplinary process follows the Employee Handbook (GTFS-HR-001).

18. Frequently Asked Questions

Q: What is the minimum password length?

A: 14 characters, as specified in GTFS-SEC-002.

Q: How often must I change my password?

A: Every 90 days maximum.

Q: How many previous passwords are blocked?

A: The last 12 passwords cannot be reused.

Q: When does my account lock?

A: After 5 failed login attempts; unlocks automatically after 30 minutes.

Q: Is MFA required?

A: Yes. MFA is mandatory for all users.

Q: What is the session timeout?

A: 20 minutes of inactivity.

Q: What is the VPN idle timeout?

A: 15 minutes per GTFS-SEC-003.

Q: What encryption is used on laptops?

A: AES-256 BitLocker.

Q: Is mobile encryption required?

A: Yes. Encryption is mandatory on all MDM-enrolled devices.

Q: How fast must critical patches be applied?

A: Within 48 hours.

Q: What about high-risk vulnerabilities?

A: Remediated within 7 days.

Q: And medium-risk vulnerabilities?

A: Remediated within 30 days.

Q: Are USB drives allowed?

A: USB storage is disabled by default.

Q: How quickly must I report phishing?

A: Immediately; no later than 15 minutes after discovery.

Q: How quickly must I report a security incident?

A: Within 30 minutes to the SOC.

Q: How much security training is required annually?

A: 8 hours of mandatory training.

Q: Are phishing simulations mandatory?

A: Yes. Quarterly simulations are required.

Q: What cloud platforms are approved?

A: Microsoft Azure and AWS for infrastructure; M365 for productivity.

Q: What is the email attachment limit?

A: 25 MB.

Q: How long are logs retained?

A: 365 days in the SIEM.

Q: Is the SOC staffed 24x7?

A: Yes. SIEM log review operates 24x7.

Q: How often is penetration testing done?

A: Twice annually.

Q: How often are vulnerability scans run?

A: Weekly.

Q: Can I use guest Wi-Fi for work?

A: Guest Wi-Fi provides internet access only; use VPN for GTFS systems.

Q: Where is the remote work policy?

A: GTFS-HR-002 supplements this policy for hybrid employees.

19. Appendices

Appendix A — Security Contacts

Function	Contact
CISO Office	ciso@gtfs.com
Security Operations Centre	security@gtfs.com +65 6123 4500
Vulnerability Management	vuln-mgmt@gtfs.com
Security Awareness	security-awareness@gtfs.com

Appendix B — Incident Reporting Process

Incident Reporting Checklist

- Identify and document what happened (time, systems, data affected)
- Do not alter or delete evidence
- Report to SOC within 30 minutes via security@gtfs.com or +65 6123 4500
- For phishing: use 'Report Phishing' in Outlook within 15 minutes
- Preserve screenshots and email headers if safe to do so
- Cooperate with SOC investigation team
- Do not discuss incident details outside authorised channels

Appendix C — Emergency Contacts

Service	Contact	Availability
SOC Hotline	+65 6123 4500	24×7
Lost Device Wipe	+65 6123 4599	24×7
IT Helpdesk	+65 6123 4530	Business hours
CISO On-Call	Via SOC escalation	24×7

Appendix D — Security Glossary

Term	Definition
AES-256	Advanced Encryption Standard with 256-bit keys.
BEC	Business Email Compromise — targeted email fraud.
BitLocker	Microsoft full-disk encryption for Windows devices.
DLP	Data Loss Prevention — controls preventing unauthorised data exfiltration.
EDR	Endpoint Detection and Response.
IDS/IPS	Intrusion Detection/Prevention Systems.

Term	Definition
MFA	Multi-Factor Authentication.
PAM	Privileged Access Management.
PCI DSS	Payment Card Industry Data Security Standard.
RBAC	Role-Based Access Control.
SIEM	Security Information and Event Management.
SOC	Security Operations Centre.
SSO	Single Sign-On.
TRM	MAS Technology Risk Management guidelines.
VPN	Virtual Private Network.
Zero Trust	Security model requiring continuous verification.

Document Control

Document ID: GTFS-SEC-001 | Version 3.2 | Classification: Internal

Approved By: Priya Raman, CISO | Effective: 01 January 2026 | Review: 01 January 2027

Generated: 28 June 2026